

Accesos no Autorizados

Divier Jacamo Álvarez

CETAV la libertad

Rol: Analista SOC L1

Fecha: Martes 24/02/26

Playbook de detención de accesos sospechosos

Introducción

La intensificación de las amenazas digitales ha aumentado la incidencia de accesos no autorizados a sistemas empresariales de acuerdo con el marco de ciberseguridad, es vital identificar eventuales problemas de forma oportuna, así como contar con pautas de manejo de incidentes que faciliten respuestas coherentes ante actividades inusuales.

En este marco, un manual para la detección de accesos sospechosos se presenta como una herramienta eficaz que estandariza la identificación temprana de patrones de autenticación irregulares, tales como intentos fallidos repetidos, accesos desde lugares inusuales o el uso indebido de credenciales privilegiadas.

Objetivo

Establecer un proceso formal para:

Detectar accesos sospechosos en sistemas de información.

Analizar eventos de autenticación inusuales.

Clasificar el nivel de riesgo asociado.

Escalar de manera adecuada al equipo de respuesta a incidentes.

Alcance

El manual se aplica a:

Sistemas corporativos internos y externos.

Infraestructura en la nube.

Redes privadas virtuales

Aplicaciones críticas del negocio.

Está destinado a analistas del Centro de Operaciones de Seguridad, administradores de sistemas y responsables de la seguridad de la información.

Marco Conceptual

La identificación de accesos sospechosos se basa en:

Análisis del comportamiento de usuarios y entidades.

Correlación de eventos en sistemas SIEM.

Modelos de riesgo fundamentados en contexto.

Principios de autenticación robusta y gestión de identidades.

Definiciones Operativas

Acceso sospechoso: Evento de autenticación que muestra discrepancias significativas respecto al comportamiento habitual del usuario o del sistema.

Indicador de compromiso: Evidencia observable que sugiere la potencial existencia de actividad maliciosa.

Evento crítico: Acceso que presenta alta probabilidad de compromiso, lo cual requiere escalamiento inmediato.

Procedimiento del Manual

1. Preparación

Configurar fuentes de registro:

Active Directory.

Servidores VPN.

Servicios en la nube.

Firewalls y proxies.

Integrar registros en una plataforma SIEM.

Definir niveles de alerta:

Más de 5 intentos fallidos en un lapso de 5 minutos.

Accesos desde países poco habituales.

Autenticaciones fuera del horario laboral.

2. Detección

Monitorear en tiempo real:

Intentos fallidos reiterados.

Uso de cuentas de alto privilegio.

Inicio de sesión desde múltiples ubicaciones en corto período.

Generar alertas automáticas cuando se alcance un nivel definido.

3. Análisis

Validar la legitimidad del acceso:

Comprobar dirección IP.

Verificar la reputación de la IP.

Correlacionar con otros eventos del usuario.

Tabla de criticidad

Nivel	Descripción	Acción
Bajo	Error de contraseña ocasional	Monitoreo
Medio	Múltiples intentos fallidos	Notificación preventiva
Alto	Acceso exitoso desde ubicación inusual	Escalamiento Inmediato

4. Contención Inicial

Bloqueo temporal de la cuenta.

Revocación de sesiones activas.

Restablecimiento de contraseña.

Activación obligatoria de autenticación multifactor.

5. Escalamiento

Escalar al Equipo de Respuesta a Incidentes cuando:

Se confirme un acceso no autorizado.

Haya indicios de movimiento lateral.

Se identifique el uso indebido de privilegios administrativos.

6. Documentación

Registrar en el sistema de gestión de incidentes:

Fecha y hora del evento.

Usuario afectado.

Evidencias recolectadas.

Acciones realizadas.

Lecciones aprendidas.

Métricas de Desempeño

Tiempo promedio de detección.

Tiempo promedio de respuesta.

Número de falsos positivos.

Porcentaje de incidentes correctamente escalados.

Consideraciones Éticas y de Cumplimiento

La implementación del manual debe alinearse con regulaciones de protección de datos personales y principios de proporcionalidad en la supervisión el acceso a los registros debe estar restringido a personal autorizado y con propósitos legítimos de seguridad.

Escenarios simulados de acceso no autorizados

Introducción

Los accesos no autorizados son una de las principales causas de incidentes de seguridad, como brechas de datos, fraudes internos y compromisos de la infraestructura crítica; la efectividad en la detección y respuesta depende del entrenamiento constante a través de simulaciones.

En este sentido, los escenarios presentados a continuación están diseñados para evaluar las

habilidades de monitoreo, correlación de eventos, análisis forense inicial y toma de decisiones en situaciones de presión.

Metodología de Construcción de Escenarios

Cada escenario incluye:

Contexto organizacional.

Vector de ataque simulado.

Indicadores de compromiso.

Nivel de criticidad.

Respuesta esperada.

Métricas de evaluación.

Escenario 1: Ataque de Fuerza Bruta a VPN Corporativa

Contexto

Una organización de tamaño medio utiliza autenticación por medio de usuario y contraseña para el acceso remoto a través de VPN.

Vector de ataque

Un atacante externo realiza múltiples intentos de autenticación automatizados contra una cuenta válida.

Indicadores de compromiso

Más de 20 intentos fallidos en un plazo menor a 3 minutos.

Dirección IP no habitual desde el extranjero.

Intentos fuera del horario laboral.

Evento crítico simulado

La cuenta finalmente es comprometida por una contraseña débil.

Nivel de criticidad

Alto.

Respuesta esperada

Bloqueo inmediato de la cuenta.

Revocación de todas las sesiones activas.

Activación obligatoria de autenticación multifactor.

Análisis de registros para descartar movimientos laterales.

Métricas de evaluación

Tiempo promedio de detección

Tiempo de contención inicial.

Escenario 2: Acceso desde Ubicación Geográfica Improbable

Contexto

Un usuario ingresa con frecuencia desde Colombia.

Vector de ataque

Se detecta un inicio de sesión en Europa 10 minutos después de un acceso exitoso
localmente.

Indicadores de compromiso

Geolocalización incoherente.

Cambio de dispositivo usado.

Activación de normas de correlación en el SIEM.

Evento crítico simulado

Acceso exitoso seguido de una descarga masiva de datos sensibles.

Nivel de criticidad

Crítico.

Respuesta esperada

Suspensión inmediata de la cuenta.

Notificación al equipo encargado de responder a incidentes.

Entrevista al usuario afectado.

Análisis de la posible exfiltración de datos.

Métricas de evaluación

Tiempo de escalamiento.

Precisión en la clasificación del incidente.

Escenario 3: Compromiso de Cuenta Privilegiada

Contexto

Un administrador de sistemas con privilegios elevados en servidores críticos.

Vector de ataque

Phishing dirigido que captura credenciales de administrador.

Indicadores de compromiso

Inicio de sesión en el servidor en horarios no habituales.

Creación de nuevas cuentas con privilegios altos.

Desactivación de registros de auditoría.

Evento crítico simulado

Intento de alterar configuraciones de seguridad.

Nivel de criticidad

Crítico.

Respuesta esperada

Aislamiento inmediato del servidor comprometido.

Rotación de credenciales privilegiadas.

Activación de un plan formal de respuesta ante incidentes.

Métricas de evaluación

Tiempo de aislamiento del sistema.

Coordinación entre departamentos.

Escenario 4: Uso Indebido Interno de Credenciales

Contexto

Un empleado con acceso legítimo intenta consultar información fuera de su área de trabajo.

Vector de ataque

Abuso de privilegios internos.

Indicadores de compromiso

Accesos repetidos a bases de datos sensibles.

Descargas masivas de información.

Alertas de comportamiento anómalo (UEBA).

Evento crítico simulado

Extracción de información confidencial hacia un dispositivo externo.

Nivel de criticidad

Alto.

Respuesta esperada

Suspensión preventiva del acceso.

Investigación disciplinaria.

Revisión de políticas de segregación de funciones.

Métricas de evaluación

Detección basada en el comportamiento.

Nivel de documentación del incidente.

La simulación de situaciones de accesos indebidos permite medir no solo la destreza tecnológica para detectar, sino también la colaboración dentro de la organización, la transparencia en el proceso de decisiones y la efectividad de los procedimientos escritos los ejercicios deben llevarse a cabo regularmente y renovarse a medida que las amenazas evolucionan.

De igual manera, asegura un método sistemático fundamentado en la identificación, salvaguarda, detección, reacción y restauración.

Documentación de playbook desarrollado

Introducción

La administración de accesos es un elemento crucial en los sistemas de seguridad de la información, ya que las credenciales son uno de los métodos de ataque más utilizados en el mundo digital actual. El acceso no autorizado puede llevar a la divulgación de datos

sensibles, modificación de activos esenciales o interrupciones en la operativa.

En línea con esta perspectiva, el presente playbook convierte los lineamientos estratégicos en procedimientos técnicos estandarizados que pueden ser aplicados por el Centro de Operaciones de Seguridad.

Propósito

El objetivo de este playbook es:

- a) Establecer criterios técnicos para detectar accesos sospechosos o no autorizados.
- b) Crear un flujo de análisis estructurado.
- c) Establecer niveles de criticidad basados en la evidencia.
- d) Asegurar la trazabilidad documental del incidente.
- e) Ayudar al fortalecimiento del sistema de gestión de seguridad de la información.

Alcance y Aplicabilidad

Este procedimiento se aplica a:

Plataformas de autenticación centralizada.

Servicios de acceso remoto (VPN).

Aplicaciones críticas para la empresa.

Infraestructura en entornos locales y en la nube.

Cuentas estándar y privilegiadas.

Su cumplimiento es obligatorio para el personal del SOC, administradores de sistemas y responsables de seguridad.

Estructura Operativa del Playbook

Fase de Preparación

La organización debe asegurar:

La centralización y correcta retención de registros (logs).

La integración de fuentes de eventos en una plataforma SIEM.

La definición de reglas de correlación y umbrales de alerta.

La implementación de autenticación multifactor (MFA) para cuentas críticas.

Además, se establecerán criterios de clasificación de eventos basados en el análisis de riesgos.

Fase de Identificación

Se considerará como evento sospechoso cuando se detecte:

Múltiples intentos fallidos de autenticación en un corto período.

Acceso exitoso desde una ubicación geográfica inusual.

Inicio de sesión simultáneo desde ubicaciones incompatibles.

Uso inusual de cuentas privilegiadas.

El analista del SOC debe validar la alerta mediante la revisión del contexto, del historial del usuario y de la reputación de la dirección IP.

Fase de Análisis y Clasificación

El análisis técnico abarcará:

La correlación con eventos anteriores o posteriores.

La revisión de cambios recientes en credenciales.

La verificación de descargas masivas o modificaciones críticas.

En función de la evidencia, el evento será clasificado como:

Riesgo Bajo: actividad irregular sin señas de compromiso.

Riesgo Medio: patrón inusual que puede indicar intrusión.

Riesgo Alto o Crítico: acceso no autorizado confirmado o que impacta significativamente.

Fase de Contención

Dependiendo del nivel de riesgo, se llevarán a cabo acciones como:

Bloqueo preventivo de la cuenta.

Restablecimiento forzado de las credenciales.

Revocación de sesiones activas.

Aislamiento temporal de sistemas comprometidos.

Estas acciones deben aplicarse siguiendo el principio de proporcionalidad y con la mínima afectación a la operación.

Fase de Escalamiento

El incidente se escalará formalmente cuando:

Se confirme el compromiso de las credenciales.

Se evidencie movimiento lateral.

Se comprometan activos cruciales.

El Equipo de Respuesta a Incidentes asumirá la gestión completa según el procedimiento institucional.

Fase de Registro y Mejora Continua

Todo evento debe ser documentado de manera exhaustiva, incluyendo:

Descripción técnica del incidente.

Evidencias recopiladas.

Acciones realizadas.

Evaluación del impacto.

Recomendaciones preventivas.

La información recopilada se utilizará para el análisis de tendencias, actualización de reglas de detección y fortalecimiento de controles internos.

Indicadores de Evaluación

Para evaluar la efectividad del playbook se utilizarán los siguientes parámetros:

Promedio de Tiempo de Detección

Promedio de Tiempo de Respuesta

Proporción de falsos positivos

Cantidad de incidentes que fueron escalados correctamente

Grado de adopción de la autenticación multifactorial.

Conclusión

La detección y gestión de accesos no autorizados representa un eje fundamental dentro de la estrategia integral de ciberseguridad de cualquier organización. En un contexto caracterizado por amenazas persistentes, automatización de ataques y explotación masiva de credenciales comprometidas, la adopción de playbooks formales y documentados permite transformar políticas generales de seguridad en procedimientos técnicos claros, repetibles y medibles.

Un enfoque estructurado basado en monitoreo continuo, análisis de comportamiento, correlación de eventos y clasificación de riesgos facilita la identificación temprana de anomalías en los procesos de autenticación esto no solo reduce los tiempos de detección y respuesta, sino que también limita el impacto potencial sobre la confidencialidad, integridad y disponibilidad de los activos de información asimismo, la incorporación de controles como

autenticación multifactor, gestión de identidades y accesos y revisión periódica de privilegios fortalece el principio de mínimo privilegio y disminuye la superficie de ataque.

Referencias

International Organization for Standardization. (2022). *ISO/IEC 27001:2022 information security management systems — Requirements*.
<https://www.iso.org/standard/27001.html>

ISO. (2025). *ISO/IEC 27001:2022 Annex A Control 5.17 — Authentication information explained*. <https://www.isms.online/iso-27001/annex-a-2022/5-17-authentication-information-2022/>

Wiefling, S., Lo Iacono, L., & Dürmuth, M. (2020). *Is this really you? An empirical study on risk-based authentication applied in the wild*. arXiv.
<https://arxiv.org/abs/2003.07622>

Ring, M., Wunderlich, S., Scheuring, D., Landes, D., & Hotho, A. (2019). *A survey of network-based intrusion detection data sets*. arXiv. <https://arxiv.org/abs/1903.02460>